

Assignment 3

1. Discuss any 3 techniques used by hackers to maintain anonymity.

1. Borrowed or stolen dial-up accounts from friends or previous employers.

- Hackers exploit trust by illicitly using dial-up credentials.
- Connect to the internet using someone else's account.
- Obscure their own identity and avoid direct association.
- Unethical and illegal, leading to severe consequences.

2. Public computers at libraries, schools or kiosks at the local mall.

- Provide convenient, anonymous internet access.
- Challenge tracing online activities back to individual users.
- Exploit lack of users authentication for anonymity.
- Using public computers for hacking is unethical and may leave digital footprints.

3. Zombies at other organizations.

- Compromise unsecured computers for anonymity.
- Control systems remotely to launch attacks.
- Create a distributed network of compromised devices.
- Complicate efforts to trace the origin of attacks and identify hackers.

2. xyz private limited wants to use certain tools for ethical hacking. Discuss some characteristics while selecting the tools.

1. **Adequate documentation:**

- Comprehensive documentation ensures clarity and understanding of the entire ethical hacking process.
- Documentation should include methodologies, tools used, findings, and any other

relevant information.

- Well-documented procedures aid in replication, verification, and future reference for both the ethical hacker and stakeholders.

2.Detailed reports on vulnerabilities:

- Reports should provide in-depth analysis of discovered vulnerabilities, including their severity, potential impact, and recommended fixes.
- Exploitation techniques should be clearly outlined to demonstrate the risk posed by each vulnerability.
- Suggestions for mitigation or remediation should accompany each vulnerability to guide effective resolution.

3.Updates and support:

- Timely updates and ongoing support are essential for maintaining the effectiveness of ethical hacking tools and methodologies.
- Regular updates ensure that tools remain compatible with evolving technologies and security standards.
- Access to technical support helps ethical hackers address any issues or challenges encountered during testing.

4.High-level reports for non-technical audiences:

- High-level reports provide a summarized overview of findings and recommendations in a format understandable to non-technical stakeholders.
- These reports focus on key insights, risks, and actionable recommendations without delving into technical jargon.
- Clear, concise language and visual aids such as charts or graphs help convey

complex information to managers or other non-technical decision-makers.

3. Identify any 3 system ports before doing ethical hacking.

- Before engaging in ethical hacking activities, it's essential to identify and understand the system ports commonly used for various network services. Here are some system ports often targeted or assessed during ethical hacking:

1. **Port 21 (FTP):** File Transfer Protocol (FTP) is used for transferring files between a client and a server. Security vulnerabilities in FTP servers can lead to unauthorized access or data breaches.
2. **Port 22 (SSH):** Secure Shell (SSH) provides secure access to a remote system over an encrypted connection. Weak SSH configurations or outdated software versions can be exploited by attackers.
3. **Port 23 (Telnet):** Telnet is a network protocol used for remote access to a command-line interface. It's considered insecure due to its lack of encryption, making it susceptible to eavesdropping and credential theft.
4. **Port 25 (SMTP):** Simple Mail Transfer Protocol (SMTP) is used for sending email messages between servers. Misconfigured SMTP servers can be abused for spamming or email spoofing attacks.
5. **Port 53 (DNS):** Domain Name System (DNS) resolves domain names to IP addresses. DNS misconfigurations or vulnerabilities can lead to DNS spoofing, cache poisoning, or denial-of-service (DoS) attacks.
6. **Port 80 (HTTP):** Hypertext Transfer Protocol (HTTP) is used for transferring web pages and content over the internet. Web servers running outdated or vulnerable software may be susceptible to various attacks, including injection attacks and server-side exploits.

7. **FTP (21):** - FTP stands for File Transfer Protocol.

- Port 21 is the default port for FTP, used for transferring files between a client and a server over a network.
- FTP operates in two modes: Active mode (PORT command) and Passive mode (PASV command).

- While FTP is widely used for file sharing and website maintenance, it's considered insecure due to its lack of encryption, making it susceptible to eavesdropping and data interception.

1. **Telnet (23):** - Telnet is a network protocol used for remote access to a command-line interface.

- Port 23 is the default port for Telnet.

- Telnet transmits data in plain text, making it vulnerable to interception and sniffing attacks.

- Due to its lack of encryption, Telnet is considered insecure and is often replaced by more secure protocols like SSH (Secure Shell).

1. **SMTP (25):** - SMTP stands for Simple Mail Transfer Protocol.

- Port 25 is the default port for SMTP, used for sending email messages between servers.

- SMTP is a critical component of email communication, responsible for delivering outgoing emails to their respective recipients.

- Vulnerabilities in SMTP servers can be exploited for spamming, email spoofing, and other malicious activities.

4. In social engineering explain relationship for information through words , action , technology.

- **Words:**

- Social engineers use persuasive language and keep conversations moving to prevent victims from questioning their motives.

- Signs of social engineering include acting overly friendly, mentioning prominent names, or bragging about authority.

- They exploit victims' emotions and manipulate them into sharing sensitive information.

- **Actions:**

- Social engineers mimic behavior to establish rapport and create familiarity.

- They may appear helpful or sympathetic to lower victims' guards and increase their willingness to share information.
 - Impersonating employees or posing as insiders helps social engineers gain trust and access to confidential information.
 - **Technology:**
 - Social engineers use technology, such as phishing emails or fake websites, to deceive victims.
 - They spoof computer names, email addresses, or network addresses to appear legitimate.
 - Hackers exploit vulnerabilities in technology to install malware or gain unauthorized access to systems.
 - Techniques include sending fake patches or creating fake pop-up windows to trick victims into disclosing information.
- Overall, social engineers exploit relationships through persuasive language, mimicry, and manipulation of technology to extract sensitive information from unsuspecting victims.

5.Explain shoulder surfing attack.

1. **Definition:** Shoulder surfing is a technique used by attackers to steal passwords or PINs by surreptitiously observing users as they enter their credentials.
2. **Proximity Requirement:** The attacker needs to be physically close to the victim without arousing suspicion, typically within viewing distance of the victim's keyboard or screen.

3. **Observation Techniques:** Attackers may employ various observation techniques, such as directly watching the user's keyboard strokes or monitoring their screen as they log in.
4. **Visual Cues:** In addition to watching the user's actions, attackers may look for visual cues that suggest the user is trying to recall their password, such as glancing around their surroundings for reminders or clues.
5. **Real-World Example:** A common scenario of shoulder surfing occurs in public places like grocery store checkout lines, where an attacker can easily observe a victim entering their PIN to authorize a transaction.
6. **Discretion:** Successful shoulder surfing requires the attacker to be discreet and blend in with their surroundings to avoid raising suspicion.
7. **Vigilance:** Users should be vigilant and aware of their surroundings, especially when entering sensitive information in public settings, to prevent falling victim to shoulder surfing attacks.
8. **Preventive Measures:** To mitigate the risk of shoulder surfing, users can shield their credentials from view by positioning themselves to block the view of their keyboard or screen and being cautious of potential observers.
9. **Education:** Awareness campaigns and education on the dangers of shoulder surfing can help users recognize and prevent such attacks.
10. **Importance of Security Practices:** Shoulder surfing highlights the importance of implementing robust security practices, such as using strong, unique passwords and being mindful of where and how credentials are entered in public spaces.

6. Compare dictionary attack and brute-force attack for cracking password. (6 marks)

- A "dictionary attack" and a "brute-force attack" are the dictionary attack for cracking password are both methods used for cracking passwords, but they differ in their approach and efficiency:

1. **Dictionary Attack:** - In a dictionary attack, the attacker uses a predefined list of words, phrases, or common passwords known as a "dictionary."

- The attack involves systematically trying each word or combination of words from the dictionary as the password.
- The dictionary may include commonly used passwords, words from a dictionary, or variations of known passwords (e.g., with numbers or special characters appended).
- This method is more efficient than a brute-force attack because it relies on a curated list of likely passwords, reducing the number of combinations that need to be tested.
- However, its effectiveness depends on the quality and comprehensiveness of the dictionary. If the password is not in the dictionary, the attack will fail.

1. **Brute-Force Attack (dictionary attack for cracking password):** - In a brute-force attack, the attacker tries every possible combination of characters until the correct password is found.

- This method is more exhaustive and time-consuming than a dictionary attack because it does not rely on a predefined list of passwords.
- Brute-force attacks systematically test all possible combinations of characters, starting from the shortest to the longest passwords, until the correct one is discovered.
- Brute-force attacks are less efficient compared to dictionary attacks, especially for longer and more complex passwords, as they require testing every possible combination, which can be computationally intensive and time-consuming.
- However, brute-force attacks are guaranteed to eventually crack any password, given sufficient time and computing power.

In summary, while both dictionary attacks and brute-force attacks are used for cracking passwords, dictionary attacks are more efficient as they rely on

predefined lists of likely passwords, while brute-force attacks systematically test all possible combinations. However, the effectiveness of both methods depends on factors such as the complexity of the password and the resources available to the attacker.

7. Elaborate on key stroke login and what are the counter measure.

Keystroke Logging:

- **Definition:** Recording of keystrokes as they are typed into a computer, often used for password cracking.
- **Legal Considerations:** Monitoring employees with keystroke logging may raise legal issues; consultation with legal counsel and approval from upper management is advised.
- **Logging Tools:**
 - Keystroke-logging applications like eBlaster, Spector Pro, and Invisible KeyLogger Stealth can be installed on monitored computers.
 - Hardware-based tools such as KeyGhost can intercept keystrokes between the keyboard and the computer.
- **Shared Computer Risks:** Shared computers can capture passwords of every user logging in, making them vulnerable to keystroke logging.
- **Countermeasures:**
 - Utilize spyware-detection programs or antivirus products to detect and prevent keystroke-logging software installation.
 - Educate users to avoid downloading random shareware or opening attachments in unsolicited emails to mitigate the risk of keystroke-logging software installation.

- Implement desktop lockdown measures through user rights settings or commercial lockdown programs like Fortres 101 or Deep Freeze to enhance system security.

8. Elaborate on denial of service and counter measures.

Definition: DoS attacks overwhelm a network host with invalid requests, exhausting its resources and disrupting legitimate services.

- **Types of DoS Attacks:**

- **Individual Attacks:**

- SYN floods: Flooding a host with TCP SYN packets.
- Ping of Death: Sending IP packets exceeding the maximum length, crashing the TCP/IP stack on many operating systems.
- WinNuke: Disabling networking on older Windows 95 and NT computers.

- **Distributed Attacks (DDoS):**

- Smurf attack: Spoofing the victim's address and flooding it with ICMP echo request packets.
- Trinoo and Tribe Flood Network (TFN) attacks: Launching packet floods from client and server-based programs to overwhelm victim machines.
- **Execution of DoS Attacks:** Hackers use custom or downloaded tools to execute DoS attacks, testing network security measures like IDS/IDP and firewalls.

- **Countermeasures:**

- **Security Patching:** Regularly test and apply security patches for network hosts, routers, firewalls, and operating systems.
- **Intrusion Detection Systems (IDS) and Intrusion Prevention Systems (IDP):**

Monitor network traffic for DoS attacks using IDS and IDP systems, or utilize network analyzers in continuous capture mode.

- **Firewall and Router Configuration:** Configure firewalls and routers to block malformed traffic and minimize IP spoofing.
- **ICMP Traffic Management:** Block all inbound ICMP traffic unless specifically needed, and limit it to specific hosts when necessary.
- **TCP/UDP Service Management:** Disable unnecessary TCP/UDP services to reduce attack surface and potential vulnerabilities.

9.Explain any 1 social engineering attack.

*Fishing for Information:**

- **Initial Research:**
 - Social engineers gather public information about their victims, often slowly over time to avoid raising suspicion.
 - Key information such as employee lists, internal phone numbers, or company calendars are sufficient for a hacker to start penetrating an organization.
- **Using the Internet:**
 - Search engines like Google provide a wealth of information with simple keywords such as company names or employee names.
 - SEC filings, financial websites, and organizational websites can yield significant insights, sometimes more than expected.
 - Hackers can purchase comprehensive background checks on individuals for a small fee, accessing public and sometimes private information within minutes.
- **Dumpster Diving:**

- Dumpster diving involves going through trash cans for information about a company.
- Confidential information such as internal phone lists, organizational charts, employee handbooks, and even password lists can be found.
- Shredding documents is effective if done properly, but inexpensive shredders with long strips are easily bypassed by determined social engineers.
- **Eavesdropping:**
 - Hackers gather information by listening in on conversations held in public places like restaurants, coffee shops, and airports.
 - Loud cell phone conversations and inadvertent disclosures in public places provide valuable insights to social engineers.
- **Physical Artifacts:**
 - Hackers look for physical artifacts like floppy disks, CD-ROMs, DVD discs, old computer cases, and backup tapes containing sensitive information.
- **Phone Systems:**
 - Hackers exploit dial-by-name features in voice-mail systems, usually accessed by pressing 0 after hours when no one answers.
 - They can hide their identities by using residential phone features like *67 to block caller ID or by manipulating business phone switch settings.
- **Voice-mail Analysis:**
 - Hackers listen to voice-mail messages to gather information about victims' whereabouts and even study their voices to impersonate them effectively.

This methodical gathering of information forms the basis for successful social engineering attacks, highlighting the importance of vigilance and

security measures
against such exploits.

10. Discuss the reason why hackers hack and compare Black and white hackers.

Aside from criminal and political motives, the reasons that hackers hack range from malice and revenge to simple boredom. Despite the image of hackers as dysfunctional loners, many are drawn to hacking by the sense of community it gives. Of course, a big part of hacking's attraction is the sense of power that comes from uncovering information you shouldn't possess. A hacker called Dead Addict once described the high that comes from discovering valuable information, followed by the low that comes from realizing you can't do anything with it.

For example, one hacker knows a little of that rush. He says that he once broke into a hazardous waste firm and found pretty evil insider information that no one Advanced Computer Forensics 645 was meant to see. Though he didn't act on the information, he did log it for possible use later—just in case he felt like being socially active. Many hackers who begin as system voyeurs graduate to more serious activities. It's easy to be lured to the dark side when you get easy gratification messing around with individuals such as for example—AOL users. Most hackers are not old enough to drive a car or vote, but they can exert power over a network.

Black Hat Hackers:

- **Motivation:** Black hat hackers engage in hacking activities for malicious purposes, often seeking financial gain, personal satisfaction, or to cause harm.
- **Legality:** Their actions are illegal and unethical as they violate computer security laws and breach systems without authorization.
- **Activities:** They exploit vulnerabilities, steal data, launch cyber attacks, and engage in criminal activities such as identity theft, fraud, or ransomware attacks.
- **Tools:** Black hat hackers use various tools and techniques to exploit weaknesses in systems, networks, or software for their malicious purposes.
- **Secrecy:** They operate covertly to avoid detection and may sell stolen data or services on underground forums or dark web marketplaces.

White Hat Hackers:

- **Motivation:** White hat hackers, also known as ethical hackers or security researchers, use their skills to identify and fix security vulnerabilities, protect systems, and enhance cybersecurity.
- **Legality:** Their actions are legal and ethical as they work with the permission of system owners or organizations to improve security and prevent cyber threats.
- **Activities:** They conduct penetration testing, vulnerability assessments, and security audits to identify weaknesses and recommend remediation measures.
- **Tools:** White hat hackers use similar tools and techniques as black hat hackers, but their intent is to strengthen cybersecurity defenses rather than exploit vulnerabilities.
- **Transparency:** They operate transparently, following ethical guidelines and disclosing any vulnerabilities or findings to relevant stakeholders to facilitate timely mitigation.

In summary, while both black hat and white hat hackers possess similar technical skills and use comparable tools, their motivations, activities, legality, and ethical considerations differ significantly. Black hat hackers engage in illegal and malicious activities for personal gain or harm, whereas white hat hackers work within legal and ethical boundaries to enhance cybersecurity and protect against cyber threats.

11.Explain the steps in developing the ethical hacking plan.

*Steps of Developing an Ethical Hacking Plan:**

1. **Getting Your Plan Approved:**

- Present your plan to relevant stakeholders, such as management or the security team, and obtain approval for conducting ethical hacking activities.

1. **Establishing Your Goals:**

- Define clear objectives for the ethical hacking engagement, such as identifying

vulnerabilities, assessing security posture, or testing incident response capabilities.

1. **Determine What Systems to Hack:**

- Identify the target systems or assets that will be included in the ethical hacking scope, considering critical infrastructure, sensitive data, and potential impact on operations.

1. **Creating Testing Standards:**

- **Timing:** Determine the duration and schedule of the testing activities, considering operational impact and maintenance windows.
- **Specific Tests:** Define the specific tests and techniques to be used, including network scanning, penetration testing, social engineering, etc.
- **Blind versus Knowledge Assessment:** Decide whether the testing will be conducted with or without prior knowledge of the target environment.
- **Locations:** Specify the locations where testing will take place, such as internal networks, external-facing systems, or physical premises.
- **Reacting to Major Exploits:** Establish protocols for handling major vulnerabilities or exploits discovered during testing, including immediate mitigation and communication procedures.
- **Silly Tests:** Include unconventional or "silly" tests to assess unexpected vulnerabilities or weaknesses in security controls.

1. **Selecting Tools:**

- Choose appropriate tools and technologies for conducting the ethical hacking activities, such as vulnerability scanners, penetration testing frameworks, social engineering toolkits, etc.

By following these steps, ethical hackers can develop a comprehensive

and effective
plan for assessing and improving the security posture of an organization
while adhering
to ethical standards and obtaining necessary approvals